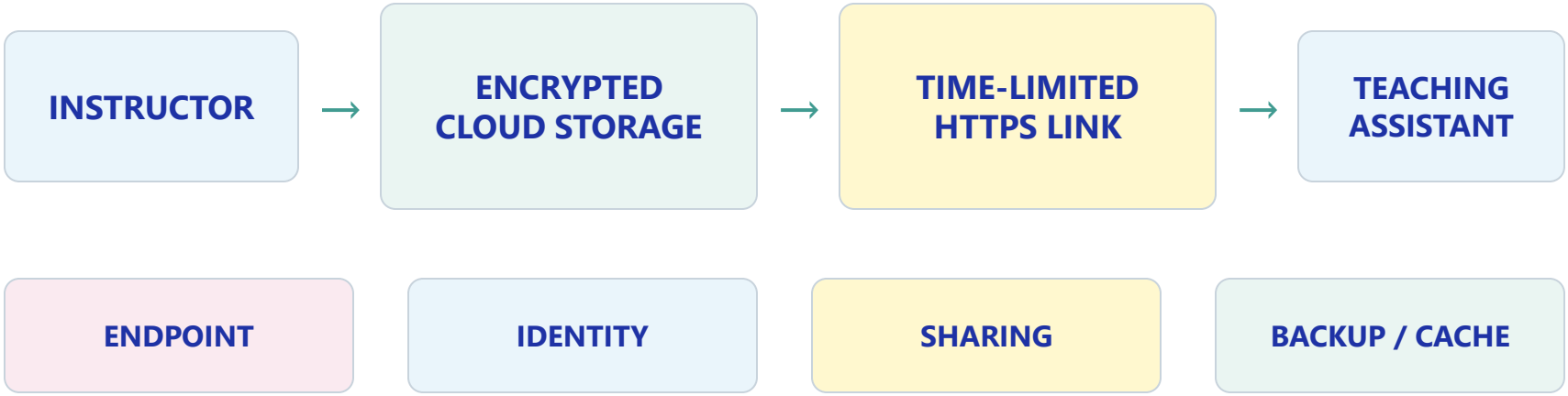
CS 6530 Applied Cryptography

Threats, Adversaries, Attack Surfaces and Threat Modelling

Foundations and Threat Modelling

THE LINK IS ENCRYPTED—BUT IS THE ANSWER KEY SECURE?

Encryption protects selected data states and paths—not the entire system.



Could the key still be disclosed, modified, or unavailable?

THE ADVERSARIAL VIEWPOINT

Security objectives state what must remain true.



Threat modelling asks how a protected outcome could become false.

LEARNING OUTCOMES

By the end, you should be able to:

- distinguish assets, vulnerabilities, threats, attacks, vectors, controls, and risk;
- describe adversaries through capabilities;
- state trust assumptions and locate trust boundaries;
- identify attack surfaces and attack paths;
- use STRIDE to discover candidate threats; and
- prioritize threats, propose layered controls, and state residual risk.

FROM AN ASSET TO RISK: USE EACH TERM PRECISELY

One connected answer-key example

ASSET

answer key

→

VULNERABILITY

over-broad sharing

→

THREAT

unauthorized disclosure

→

ATTACK

retrieve the key

VECTOR

phishing / stolen token

CONTROL

scoped access + MFA

RISK

likelihood + impact in context

ASSETS

Inventory the assets—not only the message.

DATA

messages • records • metadata

CAPABILITIES

keys • credentials • authorization

SERVICES

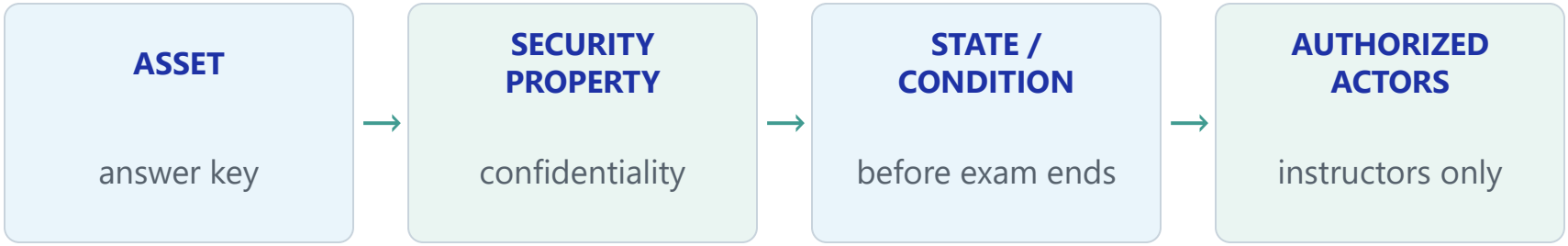
availability • recovery • safety

EVIDENCE

logs • configuration • investigation

IDENTIFY ASSETS IN CONTEXT

A useful security requirement combines four elements.



"Before the exam ends, only authorized instructors shall learn the answer-key contents—including from backups and temporary copies."

MODEL THE ADVERSARY

"A hacker" is a label—not an adversary model. Start with outsider/insider; then state capability.

GOAL

What do they want?

POSITION

Where are they?

KNOWLEDGE

What do they know?

ACCESS

What can they observe or change?

RESOURCES

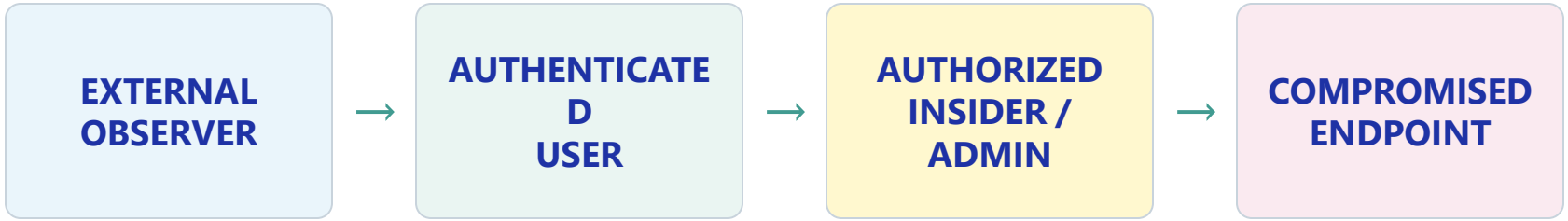
How much time and compute?

ADAPTIVENESS

Can they learn and adjust?

ADVERSARY CAPABILITIES SHAPE THE THREAT

Capabilities matter more than labels.



Evaluate controls against the strongest adversary reasonably within scope.

SECURITY MODELS AS DELIBERATE ABSTRACTIONS

A model is useful only when its assumptions match deployment.

SECURITY PROPERTY

What must remain true?

INTERACTIONS

What may the adversary do?

ASSUMPTIONS

What does the analysis retain?

Kerckhoffs's principle: keep the key secret—not the algorithm or design.

TRUST ASSUMPTIONS

A trust assumption is a condition accepted as true for the analysis.

- OS isolates processes
- RNG is adequate
- CA validates identity
- Administrator follows policy
- Clock is accurate
- Key store protects keys

"Trusted" means its compromise can violate the security property—not that failure is impossible.

TRUST BOUNDARIES

Different trust, ownership or privilege makes every crossing security-relevant.



At the boundary: authenticate • validate • authorize • log

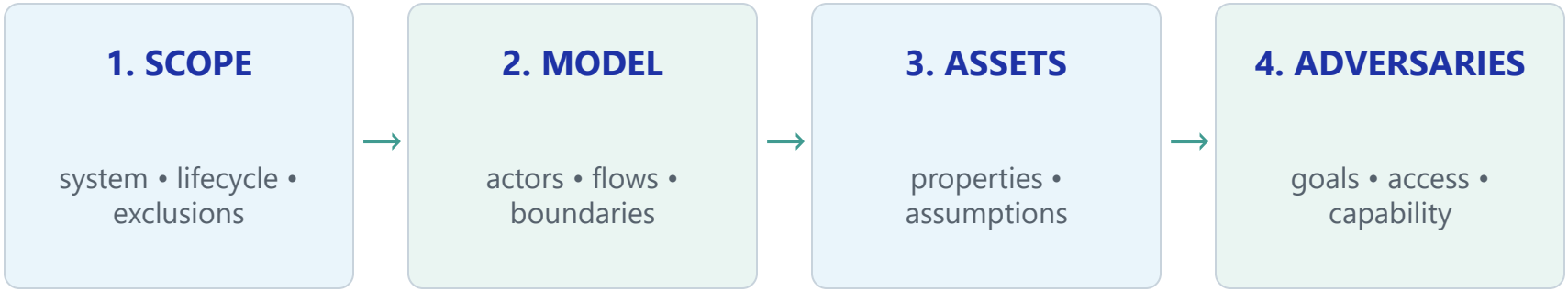
SURFACE, VECTOR, AND PATH

Different aspects of one attack scenario

ATTACK SURFACE	login page • sharing API • download API
ATTACK VECTOR	phishing leading to session-token theft
ATTACK PATH	phish instructor → steal token → invoke download API → obtain key

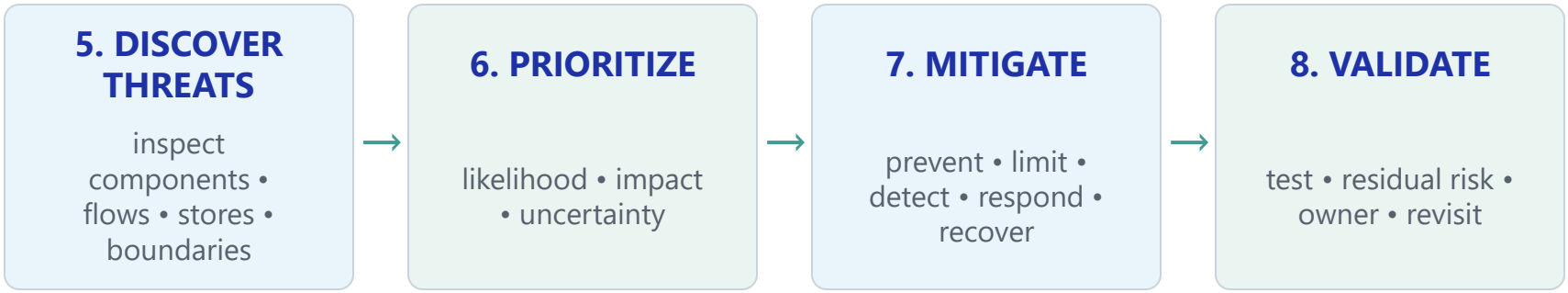
THREAT-MODELLING WORKFLOW — 1 TO 4

Build the context before listing threats.



THREAT-MODELLING WORKFLOW — 5 TO 8

Turn candidate threats into testable engineering decisions.



STRIDE

A Microsoft-originated mnemonic for systematic threat discovery.

S	**Spoofing**
T	**Tampering**
R	**Repudiation**
I	**Information disclosure**
D	**Denial of service**
E	**Elevation of privilege**

STRIDE discovers candidate threats; it is not a proof, risk score, or control catalogue.
Other approaches include attack trees, PASTA, LINDDUN and OCTAVE.

APPLY STRIDE TO THE DOCUMENT LINK

Apply categories to components, flows, stores and boundaries.

Instructor login	**Spoofing**	stolen credential or session
Sharing-policy update	**Tampering**	restricted → public
URL and metadata	**Disclosure**	logs / forwarding
Download service	**Denial of service**	legitimate access blocked
Ordinary account	**Elevation**	administrator privilege

Complete threat: An external attacker uses a stolen session token to impersonate the instructor and disclose the answer key.

FROM THREATS TO RISK

Risk considers likelihood and adverse impact; qualitative scales depend on context.

SIMPLIFIED QUALITATIVE RISK MATRIX

Impact ↑	Low	Moderate	High
High	M	H	H
Moderate	L	M	H
Low	L	L	M

Likelihood →

NIST SP 800-30 uses a more detailed five-level scale: Very Low to Very High.

ENGINEERING ACTION — TEACHING GUIDE

VERY HIGH	act immediately / avoid
HIGH	mitigate + owner + deadline
MODERATE	proportionate treatment
LOW / VERY LOW	accept, monitor, revisit

Action guidance is instructional—not prescribed by NIST.

SELECT LAYERED MITIGATIONS

Separate the risk-response decision from the control layers.

RISK-RESPONSE DECISION

AVOID	MITIGATE	TRANSFER / SHARE	ACCEPT
remove bearer link	apply controls	contract / insurance	own residual risk

IF MITIGATING: LAYERED CONTROL FUNCTIONS

PREVENT / PROTECT	LIMIT IMPACT	DETECT	RESPOND	RECOVER
MFA + authenticated access	scoped token / least privilege	unusual-download alert	revoke token / session	restore trusted permissions

CRYPTOGRAPHY'S ROLE IN MITIGATION

The threat model helps justify cryptographic—and non-cryptographic—controls.

CONFIDENTIALITY	→	encryption / AE
ORIGIN + INTEGRITY	→	MAC / signature
IDENTITY	→	password-auth / certificates
FRESHNESS	→	nonces / counters

Select controls from the required security property, adversary capability, system boundary and operational constraints. A STRIDE category alone does not determine the control.

RESIDUAL RISK AND TRACEABILITY

Residual risk is what remains after controls are applied.



State it • assign an owner • review it • accept it—or treat it further

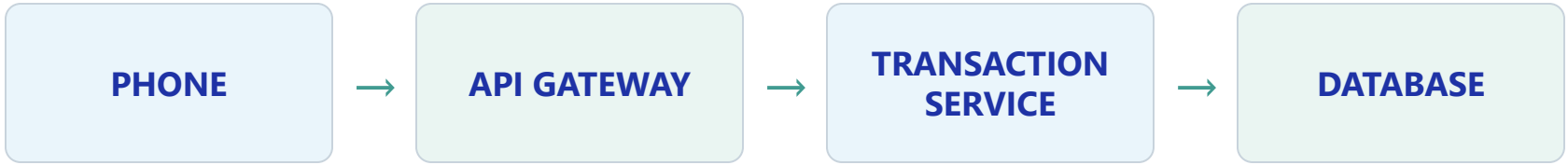
COMMON THREAT-MODELLING MISTAKES

Threat modelling fails when the model is vague, mechanical, or never revisited.

FAVORED TECHNOLOGY	start with objectives	**"HACKERS"**	state capabilities
ALL INTERNAL = TRUSTED	separate privilege domains	**COMPONENTS ONLY**	include flows + dependencies
NETWORK ONLY	include endpoint + operations	**STRIDE = RISK**	assess likelihood + impact
PREVENTION ONLY	detect + respond + recover	**ONE-TIME DOCUMENT**	revisit after change

INTEGRATED PRACTICE — CONTINUE IN THE TUTORIAL

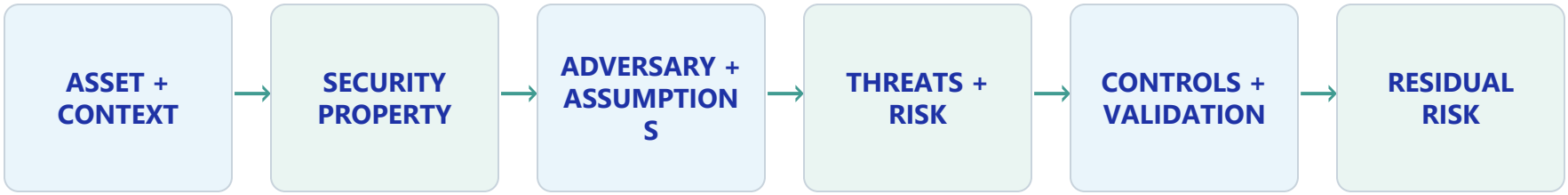
Begin as short preparation; complete and discuss it in Tutorial 1.



1. Assets
2. Adversaries
3. Boundaries
4. STRIDE threats
5. Risk priority
6. Controls + residual risk

SUMMARY AND TRANSITION

Security objectives say what should remain true; threat modelling asks how they could become false.



Later modules develop the primitives, protocols, implementations and key-management practices needed to realize selected controls.

EXIT QUESTION

SIGNED UPDATE: PROTECTED—AND UNPROTECTED?

A service signs every software update but distributes it over an unauthenticated channel.



Prepare a concise answer; we will review it in Tutorial 1.